

Software Bill of Materials Adoption: A Mining Study from GitHub

Nicolas Marcelo Rivas Rojas

¿Cuál es el problema que se está resolviendo?

El problema que aborda el artículo es la adopción de las SBOM en proyectos de código abierto alojados en GitHub. A medida que estas se vuelven esenciales para mejorar la seguridad y transparencia en la cadena de suministro de software, el estudio investiga cuánto y cómo los desarrolladores están implementando esta práctica.

¿Cuál es la nueva idea que están proponiendo?

Los autores realizan un estudio exploratorio para evaluar el nivel de adopción de las SBOM en proyectos de código abierto alojados en GitHub. Para ello, identifican repositorios que utilizan herramientas de generación de SBOM desarrolladas por SPDX y CycloneDX, encontrando 186 repositorios públicos que adoptan SBOM. Este enfoque permite medir la prevalencia y disponibilidad de SBOM en proyectos de código abierto, proporcionando una visión sobre la tendencia creciente en su adopción y destacando la necesidad de que las organizaciones actualicen su software para cumplir con los nuevos estándares de la cadena de suministro de software.

Puntos positivos

El estudio aborda un tema actual y crítico en la seguridad del software, resaltando la importancia de las SBOM en la gestión de la cadena de suministro de software.

El uso de minería de repositorios de GitHub y el análisis de herramientas como SPDX y CycloneDX proporcionan una base empírica sólida para respaldar los hallazgos.

A pesar de la baja adopción general, el estudio muestra un crecimiento en el uso de SBOMs, lo que permite comprender mejor las direcciones futuras en seguridad del software.

Puntos negativos

Aunque se identificaron 186 repositorios que adoptan SBOM, este número es relativamente pequeño en comparación con la vastedad de proyectos en GitHub, lo que podría limitar la generalización de los resultados. Además de que GitHub no representa la totalidad del desarrollo de software.

El estudio se centra en la cuantificación de la adopción de SBOM, pero no profundiza en las razones detrás de la baja adopción o en los desafíos que enfrentan los desarrolladores para implementarlas.

Trabajo futuro

Un estudio cualitativo que explore los motivos por los cuales los desarrolladores no implementan SBOM.

Investigar si los proyectos que usan SBOM tienen menos vulnerabilidades reportadas o mejores prácticas de gestión de dependencias podría validar la efectividad de esta práctica.

Calificación

(4) El artículo proporciona una visión valiosa sobre la adopción de SBOM en proyectos de código abierto, abordando un tema relevante y actual. Sin embargo, la limitada muestra y la falta de análisis cualitativo impiden una comprensión más profunda de los factores que influyen en la adopción de SBOM.

Puntos de discusión

¿Qué podría motivar o dificultar que los desarrolladores adopten SBOM en sus proyectos?

¿Son realmente útiles las SBOM en la práctica, o simplemente se han convertido en una exigencia regulatoria sin impacto real?